

HIPAA Privacy and Security Compliance Manual

Sunrise Medical Center

Document Title: HIPAA Privacy and Security Compliance Manual

Document ID: SMC-COMP-001

Department: Compliance and Privacy Office

Effective Date: April 14, 2019

Last Revised: January 30, 2026

Policy Owner: Chief Compliance and Privacy Officer, Renata Ibarra

Distribution: All Sunrise Medical Center Staff

1. Purpose

Sunrise Medical Center is a covered entity under the Health Insurance Portability and Accountability Act (HIPAA). This manual establishes the administrative, technical, and physical safeguards required to protect patient Protected Health Information (PHI) and defines the responsibilities of every workforce member with access to PHI in any form.

2. Minimum Necessary Standard

Staff may access, use, or disclose only the minimum amount of PHI necessary to perform their specific job function. Curiosity-based access to a patient's record — including friends, family, coworkers, or public figures — without a direct treatment, payment, or operations reason is strictly prohibited and constitutes a reportable privacy violation regardless of intent.

3. Permitted Uses and Disclosures

PHI may be used or disclosed without specific patient authorization for treatment, payment, and healthcare operations (TPO), as required by law, or for public health reporting. Any disclosure outside these categories requires a signed patient authorization or falls under a specific regulatory exception documented in Section 6 of this manual.

- Treatment: sharing information with other providers directly involved in the patient's care.
- Payment: submitting claims data to insurers and payers for reimbursement.
- Operations: quality improvement, credentialing, training, and administrative functions.

4. Patient Rights Under HIPAA

Patients have the right to access and obtain a copy of their medical record within 30 days of a written request, request amendments to their record, request an accounting of certain disclosures, request restrictions on how their information is used, and request confidential communications at an alternate location or phone number.

5. Breach Notification Procedure

Any workforce member who suspects or discovers an unauthorized access, use, or disclosure of PHI must report it to the Compliance and Privacy Office within 24 hours via the Confidential Compliance Hotline or the online incident form. The Privacy Officer conducts a risk assessment within 3 business days to determine if the event constitutes a reportable breach under the HIPAA Breach Notification Rule.

Breaches affecting 500 or more individuals require notification to the affected individuals, the Secretary of Health and Human Services, and prominent media outlets within 60 days of discovery, coordinated by the Compliance Office in conjunction with Legal Counsel and Communications.

6. Physical and Technical Safeguards

Workstations displaying PHI must be positioned away from public view and locked or logged off whenever unattended, even briefly. Paper records containing PHI must never be left in unsecured areas and must be shredded using designated secure bins, not standard trash or recycling.

- 1 All electronic systems containing PHI require unique user authentication; shared logins are prohibited.
- 2 Mobile devices and laptops accessing PHI must be encrypted and enrolled in the hospital's Mobile Device Management platform.
- 3 Remote access to clinical systems requires multi-factor authentication and an approved VPN connection.
- 4 PHI must never be transmitted via personal email, personal messaging apps, or unencrypted fax to unverified recipients.

7. Workforce Training

All new employees, contractors, and volunteers complete HIPAA privacy and security training before receiving system access, with annual refresher training mandatory for continued access. Training completion is tracked in the Learning Management System and audited quarterly by Human Resources and Compliance.

8. Sanctions for Non-Compliance

Violation Category	Example	Typical Sanction
Unintentional/first occurrence	Accessing a coworker's record out of curiosity, self-reported	Formal counseling, retraining
Repeated or negligent	Leaving PHI visible on unattended workstation repeatedly	Written warning, suspension
Willful/malicious	Selling or disclosing PHI for personal gain	Termination, referral to law enforcement

9. Related Documents

SMC-IT-030 Data Security and Access Control Policy; SMC-COMP-004 Confidential Compliance Hotline Procedure; SMC-HR-019 Workforce Sanctions Policy; SMC-COMP-011 Business Associate Agreement Standards.

Appendix A: Frequently Asked Questions

Q: Can a staff member look up their own medical record in the hospital system? A: Staff should use the official Patient Portal or formal medical records request process rather than direct clinical system access, even for their own record, to maintain clear audit trails.

Q: Is it acceptable to discuss a patient case in a hospital elevator or cafeteria? A: No. Any discussion of identifiable patient information in public or semi-public areas is a privacy violation, even without using the patient's name, if the details make the patient identifiable.

Q: What should I do if I receive a fax containing PHI intended for another organization? A: Do not read further than necessary to identify the error, notify the Privacy Office immediately, and follow the misdirected PHI reporting procedure; do not forward or discard it without instruction.

Q: Do volunteers and students need HIPAA training? A: Yes, anyone with potential access to PHI, including volunteers, students, and contracted vendors, must complete HIPAA training before being granted any system or physical access.

Appendix B: Common Scenarios

Scenario — Media inquiry about a high-profile patient: All media inquiries regarding any patient, regardless of public interest, are directed to the Communications Department; clinical staff must never confirm or deny a patient's presence or condition directly to media.

Scenario — Family member calling for updates: Staff must verify the caller is listed on the patient's authorized contact list or has the assigned care partner passcode before sharing any clinical information over the phone.

Revision History

Version	Date	Description
1.0	Apr 14, 2019	Initial release
2.0	Jun 6, 2022	Restructured around 2021 HHS Recognized Security Practices guidance
2.3	Jan 30, 2026	Updated breach risk-assessment timeline and MFA requirement